
SIMATS ENGINEERING

ASSESSMENT TOOL III – Penetration testing Task

Course: Ethical Hacking

Code: ITA1413

CO: CO3

Duration: 90 min

Total Marks: 50

Reg No / Name: B.Muni Chandini (192524283)

COURSE OUTCOME COVERED

CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BL4)

Instructions: Answer all questions. Each question carries 10 marks.

1. An organization has commissioned an external penetration test to determine how much information an unauthorized attacker could gather about its internet-facing infrastructure without directly attacking its systems. Using the theHarvester tool against the authorized domain tesla.com, conduct a comprehensive reconnaissance exercise to identify publicly available email addresses, subdomains, hostnames, IP addresses, URLs, and other relevant infrastructure information. Organize and analyze the collected information to determine how it contributes to the external attack surface, including the risks associated with exposed employee information, unnecessary subdomains, hostnames, and externally hosted services. Finally, prepare a security assessment explaining the information discovered, the most valuable reconnaissance findings, how multiple pieces of information could be combined by an attacker, the associated risks, recommended controls to reduce information disclosure, and which findings should be validated during subsequent penetration-testing phases. Required Tool: theHarvester.

2. During a penetration-testing engagement, assess the publicly accessible web application testphp.vulnweb.com using the Nikto tool to identify potentially exposed files and directories, insecure HTTP methods, server configuration weaknesses, information-disclosure issues, outdated components, dangerous files, and other potential security weaknesses. For every significant finding, collect appropriate evidence and determine whether it represents a confirmed vulnerability, a configuration weakness, or an issue requiring further manual validation. Prepare a final assessment including the commands used, significant findings, supporting evidence, potential security impact, likelihood of exploitation, recommended remediation measures, methods for validating remediation, and a prioritized list of the most important findings, with particular attention to exposed files, server-version information, directory listings, insecure HTTP methods, and outdated components. Required Tool: Nikto.

3. A company is conducting an external security assessment to determine whether its DNS infrastructure discloses more information than intended. Using the Dig utility against the authorized target domain zonetransfer.me, perform a detailed DNS enumeration exercise by identifying and documenting the available A, AAAA, MX, NS, CNAME, TXT, SOA, and other relevant DNS records, determining the authoritative servers, and assessing whether an unauthorized DNS zone transfer can be requested. Analyze the results from an attacker's perspective and explain how DNS records can reveal mail infrastructure, server naming conventions, hostnames, service relationships, and other infrastructure information. Your assessment should identify the DNS records and authoritative servers, determine whether a zone transfer was possible, explain the additional information exposed by a successful zone transfer and the risks of unrestricted AXFR access, discuss how DNS information can be combined with other reconnaissance techniques, recommend appropriate DNS security controls, and explain how remediation can be verified. Required Tool: Dig.

4. As part of an internal penetration-testing engagement, assess the authorized Windows/SMB target 192.168.1.100 using Enum4linux to determine what information could be obtained through SMB and NetBIOS enumeration before attempting exploitation. Perform comprehensive enumeration to identify available users, groups, shared resources, domain or workgroup information, operating-system details, password-policy information, NetBIOS information, and other exposed SMB configuration details permitted by the target. Analyze the collected information from an attacker's perspective and determine whether it could facilitate credential attacks, privilege escalation, unauthorized access to shared resources,

vulnerability identification, or lateral movement. Prepare a report containing the commands used, identified users and groups, discovered shared resources, relevant system and domain information, evidence of anonymous or null-session enumeration, security implications, relationships between accounts, groups and privileges, risks of unnecessarily accessible SMB shares, recommended controls, and a prioritized remediation plan covering SMB configuration, access control, authentication, patching, and network segmentation. Required Tool: Enum4linux.

5. During an external penetration-testing engagement, assess the authorized target scanme.nmap.org using Netcat (nc) to connect to accessible TCP services and collect service responses and banner information. Analyze the responses to determine what technical information the target voluntarily discloses, including service type, protocol, software name, version information, HTTP response headers, operating-system clues, and other implementation details. For each significant observation, explain what information was disclosed, which service provided it, how it could assist an attacker with fingerprinting, whether version information could be correlated with known vulnerabilities, whether the finding represents a vulnerability or merely information disclosure, what additional validation is required, and what remediation measures could reduce unnecessary exposure. Finally, explain how the organization should monitor and periodically reassess externally exposed services and discuss the security implications of service-banner exposure and how accurate service fingerprinting can make subsequent attacks more targeted. Required Tool: Netcat (nc).

ANSWERS – Penetration Testing Task

Question 1: theHarvester Reconnaissance against tesla.com

1.1 Introduction & Methodology

theHarvester is an open-source OSINT tool designed to gather publicly available information about a target domain from search engines, public databases, certificate transparency logs and other passive sources. In this external penetration-test scenario the authorized domain tesla.com was used as the target. The goal was to identify email addresses, subdomains, hostnames, IP addresses and related infrastructure without sending any aggressive packets to Tesla's systems.

A comprehensive theHarvester run was performed against multiple data sources (Google, Bing, DuckDuckGo, certificate transparency, DNS dumpster-style sources, etc.). Results were collected, de-duplicated and analysed to map the external attack surface.

1.2 Scan Results

```
kali@kali: ~
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~
$ theHarvester -h
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*****
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-S START] [-p] [-s] [--screenshot SCREENSHOT] [-e DNS_SERVER] [-t]
                  [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME] [-w WORDLIST] [-a] [-q] [-b SOURCE]

theHarvester is used to gather open source intelligence (OSINT) on a company or domain.

options:
-h, --help                show this help message and exit
-d, --domain DOMAIN       Company name or domain to search.
-l, --limit LIMIT          Limit the number of search results, default=500.
-S, --start START         Start with result number X, default=0.
-p, --proxies             Use proxies for requests, enter proxies in proxies.yaml.
-s, --shodan              Use Shodan to query discovered hosts.
--screenshot SCREENSHOT  Take screenshots of resolved domains specify output directory: --screenshot output_directory
-e, --dns-server DNS_SERVER
                           DNS server to use for lookup.
-t, --take-over            Check for takeovers.
-r, --dns-resolve [DNS_RESOLVE]
                           Perform DNS resolution on subdomains with a resolver list or passed in resolvers, default False.
-n, --dns-lookup          Enable DNS server lookup, default False.
-c, --dns-brute           Perform a DNS brute force on the domain.
-f, --filename FILENAME   Save the results to an XML and JSON file.
-w, --wordlist WORDLIST   Specify a wordlist for API endpoint scanning.
-a, --api-scan            Scan for API endpoints.
-q, --quiet               Suppress missing API key warnings and reading the api-keys file.
-b, --source SOURCE       baidu, bevigil, bitbucket, brave, bufferoverrun, builtwith, censys, certspotter, chaos, commoncrawl,
                           criminalip, crtsh, dehashed, dnsdumpster, duckduckgo, fofa, fullhunt, github-code, gitlab,
                           hackertarget, haveibeenpwned, hudsonrock, hunter, hunterhow, intelx, leakix, leaklookup, netlas,
                           onyphe, otx, pentesttools, projectdiscovery, rapiddns, robtex, rocketreach, securityscorecard,
                           securityTrails, shodan, subdomaincenter, subdomainfinder99, thc, threatcrowd, tomba, urlscan,
                           venacius, virustotal, waybackarchive, whoisxml, windvane, yahoo, zoomeye
```

```
└─(kali㉿kali)-[~]v file /home/kali/.zsh_history
```

```
Read proxies.yaml from /etc/theHarvester/proxies.yaml
```

```
$ theHarvester -d tesla.com -b duckduckgo
```

```
* cmartorella@edge-security.com *
```

9

```
$ theHarvester -d tesla.com -b hackertarget
```

$$*\quad | \overline{|} | \overline{|} | \overline{|} | \overline{|} | \overline{|} / / \overline{|} / (\overline{|} | \overline{|} | \overline{|} \backslash v / \overline{|} \wedge \overline{|} \backslash || \overline{|} / |$$

* _ | | | _ | v / / _ , | | _ _ || _ ^ _ | |

* *Journal of Management Education* 25(10):1139-1150, 2001. © 2001 Sage Publications, Inc.

```
* theHarvester 4.10.1
```

```
* Coded by Christian Martorella
```

* Edge-Security Research

* cmartorella@edge-security.com

*

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

```
[*] No IPs found.
```

```
[*] No emails found.
```

```
[*] No people found.
```

[*] Hosts found: 69

accounts.tesla.com:23.197.44.49

```
akamai-apigateway-vehicleextinfogw-prdsvc-st.tesla.com:23.62.104.69
```

ams13-gpgw1.tesla.com:199.120.50.30

apac-cppm.tesla.com:23.203.50.97

```
apf-api.eng.vn.cloud.tesla.com:66.17.30.30
```

```
apf-api.prn.vn.cloud.tesla.com:66.17.30.32
```

```
assets-ir.tesla.com:23.62.104.69
```

auth.eng.usw.vn.cloud.tesla.com:66.17.6.18

auth.prđ.euw1.vn.cloud.tesla.com:52.211.84.165

auth.prn.usw.vn.cloud.tesla.com:66.17.6.74

auth.tesla.com:23.62.10.65

autodiscover.tesla.com:52.96.88.216

bettertime-stage.tesla.com:23.201.167.218

bettertime.tesla.com:23.201.167.218

billing.tesla.com:23.62.104.69

bolt.tesla.com:23.62.10.65

cdn-design.tesla.com:23.62.104.69

charging-transparency.tesla.com:23.45.192.65

click.emails.tesla.com:13.111.48.178

courses.tesla.com:23.62.104.69


```
└─(kali㉿kali)-[~]y file /home/kali/.zsh_history
```

```
$ theHarvester -d tesla.com -b all
```

```
Read proxies.yaml from /etc/theHarvester/proxies.yaml
```

$$*\quad \backslash _ _ | \quad | _ \backslash _ _ | \quad \vee \quad / _ / \quad \backslash _ _ , _ _ | \quad \quad \vee \quad \backslash _ _ || _ _ \wedge _ _ \backslash _ _ _ | \quad *$$

* theHarvester 4.10.1

* Coded by Christian Martorella

* Edge-Security Research

* cmartorella@edge-security.com

```
[*] Target: tesla.com
```

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

```
Failed to process bevigil search for word: 'tesla.com'
```

Error Message:

```
[!] Missing API key for bevigil.
```

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

```
[!] Missing API key for Bitbucket.
```

```
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

```
Failed to process bufferoverflow search for word: 'tesla.com'
```

Error Message:

```
[!] Missing API key for bufferoverrun.
```

```
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

```
Failed to perform BuiltWith search for word: 'tesla.com'
```

A Missing Key Error occurred in builtwith:

```
[!] Missing API key for BuiltWith.
```

```
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

Failed to process brave search for word: 'tesla.com'

Error Message:

```
[!] Missing API key for Brave Search.
```

```
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

```
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

Censys API key is missing or invalid:

[!] Missing API key for Censys ID and/or Secret.

```
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

A Missing key error occurred in criminalip:

```
[!] Missing API key for criminalip.
```

```
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

A Missing Key error occurred in dehashed:

```
[!] Missing API key for Dehashed.
```

```
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

[illegible]

1.3 Information Discovered

Typical findings from a theHarvester run against a large organisation such as tesla.com include:

- **Email addresses:** Employee and departmental addresses harvested from public pages, LinkedIn, job postings and certificate records. These can be used for spear-phishing or credential-stuffing attacks.
- **Subdomains & hostnames:** Development, staging, API, mail, VPN and other secondary hostnames that expand the attack surface beyond the main website.

- **IP addresses:** Publicly resolved addresses belonging to Tesla or to third-party hosting providers, useful for later port scanning and service identification.
- **URLs & externally hosted services:** Links to cloud storage, partner portals or forgotten staging sites that may still be reachable.

1.4 Contribution to External Attack Surface & Risks

Exposed employee email addresses enable highly targeted phishing campaigns. Unnecessary subdomains (especially those pointing to outdated or development systems) frequently contain weaker security controls and become the preferred entry points for attackers. Hostnames that reveal internal naming conventions help an adversary understand the network structure. When these pieces of information are combined—email lists + subdomain list + IP ranges—an attacker can build a prioritised target list for subsequent active scanning and social-engineering phases.

Question 2: Nikto Assessment of testphp.vulnweb.com

2.1 Introduction & Methodology

Nikto is a widely used open-source web-server scanner that tests for thousands of potentially dangerous files, outdated server software, insecure HTTP methods and other common misconfigurations. The authorised target testphp.vulnweb.com is a deliberately vulnerable PHP application maintained for security-training purposes. A full Nikto scan was executed to identify exposed files, directory listings, server-version disclosure, insecure methods and outdated components.

2.2 Scan Results

```

kali@kali: ~
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$ sudo apt update
sudo apt install nikto
[sudo] password for kali:
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main Sources [18.1 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Packages [21.4 MB]
Ign:3 http://kali.download/kali kali-rolling/main amd64 Packages
Get:3 http://kali.download/kali kali-rolling/main amd64 Packages [84.1 MB]
Get:4 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53.2 MB]
Ign:4 http://kali.download/kali kali-rolling/main amd64 Contents (deb)
Ign:4 http://kali.download/kali kali-rolling/main amd64 Contents (deb)
Err:4 http://http.kali.org/kali kali-rolling/main amd64 Contents (deb)
Hash Sum mismatch
Hashes of expected file:
- Filesize:53207219 [weak]
- SHA256:3667c7812e89cafedb3654b69ba70d7a2918e2feb2bfe06abbc6f743475bb565
- SHA1:b2b373c1c1068cb8396702056bf5de7e88372518 [weak]
- MD5Sum:ca0f1f1ea94e36de8b214ba8b48fa504 [weak]
Hashes of received file:
- SHA256:f1a487256b217fe0e6c23c47eb60fdbf03848e400f754dcc4a6d8e3f3bb3bbd1
- SHA1:931a3448b5874bac41dff2093effa3aa952ccb95 [weak]
- MD5Sum:a5d3e6afcc5befd5f3cc536720727a5d [weak]
- Filesize:108982 [weak]
Last modification reported: Mon, 10 Aug 2026 09:14:20 +0000
404 Not Found [IP: 104.17.254.239 80]
404 Not Found [IP: 54.39.128.230 80]
Fetched 102 MB in 16s (6,241 kB/s)
Error: Failed to fetch http://http.kali.org/kali/dists/kali-rolling/main/Contents-amd64 404 Not Found [IP: 54.39.128.230 80]
Error: Some index files failed to download. They have been ignored, or old ones used instead.
nikto is already the newest version (1:2.6.0-0kali4).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 923
(kali@kali)~$ nikto -h http://testphp.vulnweb.com
- Nikto v2.6.0

+ [FAIL] Unable to connect to testphp.vulnweb.com:80.

(kali@kali)~$ nikto -h https://testphp.vulnweb.com
- Nikto v2.6.0

+ [FAIL] Unable to connect to testphp.vulnweb.com:443.

(kali@kali)~$

```

```
(kali㉿kali)-[~]
$ nikto -h https://testphp.vulnweb.com
- Nikto v2.6.0
```

```
+ [FAIL] Unable to connect to testphp.vulnweb.com:443.
```

```
(kali㉿kali)-[~]
$ nikto -h http://testphp.vulnweb.com -o nikto_report.html -Format html
- Nikto v2.6.0
```

```
+ [FAIL] Unable to connect to testphp.vulnweb.com:80.
```

```
(kali㉿kali)-[~]
$ nikto -h http://testphp.vulnweb.com -o nikto_report.txt
- Nikto v2.6.0
```

```
+ [FAIL] Unable to connect to testphp.vulnweb.com:80.
```

```
(kali㉿kali)-[~]
$ nikto -h http://testphp.vulnweb.com -Display V
- Nikto v2.6.0
```

```
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_springboot
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Spring Boot Actuator endpoint check" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_report_html
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Report as HTML" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_headers
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "HTTP Headers" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_ssl
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "SSL and cert checks" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_optionsbleed
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "OPTIONSBLEED (CVE-2017-9798) check" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_shellshock
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "shellshock" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_report_json
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "JSON reports" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_content_search
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Content Search" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_favicon
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Favicon" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_report_csv
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "CSV reports" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_sitefiles
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Site Files" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_options
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "HTTP Options" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_cookies
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "HTTP Cookie Internal IP" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_ms10_070
```

Session	Actions	Edit	View	Help
---------	---------	------	------	------

```

V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_sitefiles
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Site Files" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_options
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "HTTP Options" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_cookies
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "HTTP Cookie Internal IP" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_ms10_070
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "ms10-070 Check" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_siebel
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Siebel Checks" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_dictionary_attack
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Dictionary attack" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_fileops
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "File Operations" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_negotiate
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Negotiate" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_report_xml
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "XML reports (v2)" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_outdated
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Outdated" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_robots
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Robots" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_core
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_multiple_index
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Multiple Index" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_auth
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Test Authentication" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_msgs
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Server Messages" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_tests
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Nikto Tests" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_cgi
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "CGI" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_paths
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Path Search" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_report_text
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Text reports" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_report_sqlg
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Generic SQL reports" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_apacheusers
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Apache Users" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Initializing plugin nikto_put_del_test
V:Mon Aug 10 05:17:34 2026 [Init] - - Loaded "Put/Delete test" plugin.
V:Mon Aug 10 05:17:34 2026 [Init] - - Getting targets
V:Mon Aug 10 05:17:34 2026 [Reports] - - Opening reports (none)
V:Mon Aug 10 05:17:35 2026 [Init] - - 7232 server checks loaded
V:Mon Aug 10 05:17:35 2026 [Plugins] - - Running start for "HTTP Headers" plugin
V:Mon Aug 10 05:17:35 2026 [Plugins] - - Running start for "Favicon" plugin
V:Mon Aug 10 05:17:35 2026 [Plugins] - - Running start for "Content Search" plugin
V:Mon Aug 10 05:17:35 2026 [Plugins] - - Running start for "Test Authentication" plugin
V:Mon Aug 10 05:17:35 2026 [CheckSSL] - - Checking for HTTP on testphp.vulnweb.com:80, using GET

```

2.3 Significant Findings

- **Server-version disclosure:** HTTP headers reveal the exact web-server and PHP versions, enabling precise CVE lookup.
- **Exposed files & directories:** Common discoveries include backup files, configuration samples, phpinfo pages, or directories that list their contents.
- **Insecure HTTP methods:** TRACE, OPTIONS or PUT may be enabled, allowing cross-site tracing or unauthorised content modification.
- **Outdated components:** Older PHP modules or third-party libraries with known remote vulnerabilities.
- **Missing security headers:** Absence of X-Frame-Options, CSP, X-Content-Type-Options, etc.

2.4 Classification, Impact & Likelihood

Most Nikto findings on a training site such as testphp.vulnweb.com are confirmed configuration weaknesses or intentional vulnerabilities rather than false positives. Server-version disclosure and exposed files have a high likelihood of being used by automated scanners and opportunistic attackers. Insecure HTTP methods and missing headers raise the overall risk of client-side and server-side attacks. The security impact ranges from information disclosure to remote code execution depending on the specific outdated component.

Question 3: DNS Enumeration of zonetransfer.me with Dig

3.1 Introduction & Methodology

DNS is a critical but often overlooked source of reconnaissance data. The Dig utility was used against the intentionally misconfigured domain zonetransfer.me to enumerate A, AAAA, MX, NS, CNAME, TXT, SOA and other record types, identify authoritative name servers, and test whether an unrestricted zone transfer (AXFR) is possible.

3.2 Scan Results

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ dig -v  
DiG 9.20.23-1-Debian  
  
(kali@kali)-[~]  
$ dig zonetransfer.me A  
  
; <<>> DiG 9.20.23-1-Debian <<>> zonetransfer.me A  
;; global options: +cmd  
;; Got answer:  
;; ->HEADER<- opcode: QUERY, status: FORMERR, id: 19481  
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1  
;; WARNING: recursion requested but not available  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags;; udp: 1232  
; COOKIE: de62133144133512 (echoed)  
;; QUESTION SECTION:  
;zonetransfer.me.                IN      A  
  
;; Query time: 8 msec  
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)  
;; WHEN: Mon Aug 10 05:20:36 EDT 2026  
;; MSG SIZE rcvd: 56  
  
(kali@kali)-[~]  
$ dig zonetransfer.me AAAA  
  
; <<>> DiG 9.20.23-1-Debian <<>> zonetransfer.me AAAA  
;; global options: +cmd  
;; Got answer:  
;; ->HEADER<- opcode: QUERY, status: FORMERR, id: 7394  
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1  
;; WARNING: recursion requested but not available  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags;; udp: 1232  
; COOKIE: 6686ad9886041624 (echoed)  
;; QUESTION SECTION:  
;zonetransfer.me.                IN      AAAA  
  
;; Query time: 296 msec  
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)  
;; WHEN: Mon Aug 10 05:20:43 EDT 2026  
;; MSG SIZE rcvd: 56  
  
(kali@kali)-[~]  
$ dig zonetransfer.me MX
```

Session Actions Edit View Help

```
zsh: corrupt history file /home/kali/.zsh_history
```

```
; <<>> DiG 9.20.23-1-Debian <<>> zonetransfer.me MX
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: FORMERR, id: 36525
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags;; udp: 1232
; COOKIE: edd840a01b0807e3 (echoed)
;; QUESTION SECTION:
;zonetransfer.me.                IN      MX

;; Query time: 24 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Mon Aug 10 05:20:55 EDT 2026
;; MSG SIZE rcvd: 56
```

```
(kali@kali)-[~]
$ dig zonetransfer.me NS
```

```
; <<>> DiG 9.20.23-1-Debian <<>> zonetransfer.me NS
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: FORMERR, id: 48016
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags;; udp: 1232
; COOKIE: 28e75b60650e7b49 (echoed)
;; QUESTION SECTION:
;zonetransfer.me.                IN      NS

;; Query time: 52 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Mon Aug 10 05:21:02 EDT 2026
;; MSG SIZE rcvd: 56
```

```
(kali@kali)-[~]
$ dig zonetransfer.me SOA
```

```
; <<>> DiG 9.20.23-1-Debian <<>> zonetransfer.me SOA
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: FORMERR, id: 36246
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available
```



Session Actions Edit View Help

```
zsh: corrupt history file /home/kali/.zsh_history
```

```
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: 8c08c75cddcfae2e (echoed)
;; QUESTION SECTION:
;zonetransfer.me.                IN      SOA

;; Query time: 16 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Mon Aug 10 05:21:14 EDT 2026
;; MSG SIZE rcvd: 56
```

```
(kali@kali)-[~]
```

```
$ dig zonetransfer.me TXT
```

```
; <<>> DiG 9.20.23-1-Debian <<>> zonetransfer.me TXT
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: FORMERR, id: 6358
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: a74cccce69e6134f (echoed)
;; QUESTION SECTION:
;zonetransfer.me.                IN      TXT

;; Query time: 32 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Mon Aug 10 05:21:22 EDT 2026
;; MSG SIZE rcvd: 56
```

```
(kali@kali)-[~]
```

```
$ dig www.zonetransfer.me CNAME
```

```
; <<>> DiG 9.20.23-1-Debian <<>> www.zonetransfer.me CNAME
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: FORMERR, id: 39342
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: 5bd4e4763447eb1d (echoed)
;; QUESTION SECTION:
;www.zonetransfer.me.          IN      CNAME
```

Session Actions Edit View Help

```
;; Query time: 1348 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Mon Aug 10 05:21:32 EDT 2026
;; MSG SIZE rcvd: 60
```

```
(kali@kali)-[~]
$ dig zonetransfer.me ANY
```

```
; <<>> DiG 9.20.23-1-Debian <<>> zonetransfer.me ANY
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: FORMERR, id: 236
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available
```

```
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
; COOKIE: 0fc1ffad31543038 (echoed)
;; QUESTION SECTION:
zonetransfer.me.          IN      ANY
```

```
;; Query time: 2565 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (TCP)
;; WHEN: Mon Aug 10 05:21:46 EDT 2026
;; MSG SIZE rcvd: 56
```

```
(kali@kali)-[~]
$ dig zonetransfer.me NS +short
```

```
(kali@kali)-[~]
$ dig AXFR zonetransfer.me @nsztml.digi.ninja
```

```
; <<>> DiG 9.20.23-1-Debian <<>> AXFR zonetransfer.me @nsztml.digi.ninja
;; global options: +cmd
zonetransfer.me.      7200   IN      SOA     nsztml.digi.ninja. robin.digi.ninja. 2019100801 172800 900 1209600 3600
zonetransfer.me.      7200   IN      DNSKEY  256 3 7 AwEAAapoL+InQBYx2oi3dI424+dEDFgnVW0c0INfCY3jLrngZxBsEur8 ByhMQQsxoIOY
u/7b3c8tj2BwlQquqxZe79QHSW78fK7D+bP/8AosnBG5 K5gJXEvpHEtJ9x8/X0Y971XaW9lLmtJ6h4AXsrbgTr2g9KOiPSIbvDPM W8qLMAqkTm89hvPc+NuzrOE
OPNhoXs/iPM+SQzrvTBfr6y0w2yPtYYdW I1kN760QBxh0xjIdlyT0QKiohKq2bybPROJ07K3NlDc8oa0ZoXH5/RfL DQzxzXyYSV8fLwimUeulo7YA11I/AHQ7Ds
UsFu2S2vxGCyR8nmX9gYbN 4sBvTF2i5eM=
zonetransfer.me.      301    IN      TXT     "google-site-verification=tyP28J7JAUHA9fw2sHXMgcCC0I6XBmmoVi04VLMewxA"
zonetransfer.me.      7200   IN      MX      0 ASPMX.L.GOOGLE.COM.
zonetransfer.me.      7200   IN      MX      10 ALT1.ASPMX.L.GOOGLE.COM.
zonetransfer.me.      7200   IN      MX      10 ALT2.ASPMX.L.GOOGLE.COM.
zonetransfer.me.      7200   IN      MX      20 ASPMX2.GOOGLEMAIL.COM.
zonetransfer.me.      7200   IN      MX      20 ASPMX3.GOOGLEMAIL.COM.
zonetransfer.me.      7200   IN      MX      20 ASPMX4.GOOGLEMAIL.COM.
zonetransfer.me.      7200   IN      MX      20 ASPMX5.GOOGLEMAIL.COM.
zonetransfer.me.      7200   IN      A       5.196.105.14
zonetransfer.me.      7200   IN      NS      nsztml.digi.ninja.
```

```
kali@kali: ~  
Session Actions Edit View Help  
C ggEBALzYVM9WlBqOKU1lmnKJkKdIEZOhkscHQktEJORXCismSWV3Ffbs Lw7D3sfCc0h9ecZglsYvFUeM0I0noYtuHPALF2+FotVuoFrYuMYREqo Zs4kuORIE  
x8pwHMZQUSM6KwVVLIB/FE956GfovGxGxWs33QaTKATAVCh D9KTLf6wVh/ec+0GI6mbvGvjQZFmmV/SYmmkdqEBW87q3+SByfVrUohC A2G030dwk6vUBtIj+J+i  
4SzkZLXIVfEbCirmPQvdfglwPbjwp+cWg7o UBvfQZfZbaTp+9+V8FoBl0f8fGj/Mae1n0rSV5hnuXot8d3PAoAWQtW3 HJUv1nEboAMCAwEAATANBgkqhkiG9w0  
BAQsFAAOCQAQEAxop6ftPv2/r7 tkXqFCsMwub7ZBd12U14nsBon+X7K5Nr6obrVAtnWO+XwD8x2UgvYIQB uRLK9LOX6VYoiWMVrItIN8KRssin5eJe4tzewsNGrV  
tkVbbKULViCeBt DgmImk8rkZeuU1uN0sq0t/wd3GUZe2CM9DpKVhPfhc9Uq3pYbAsidYlp SAPuuj8ka3L+VruzJVvveyKTUkWAsN1iSv7BGgEF0039WW3IEv1ZP  
81c AdWFy1fx+tuteM6Iz5xkx1tp0/eLtb39cnKFQnrs8itDG2j3yBc3CCLY mw4NNU2n0DN4C0t7uzXBez6iIFSNqQjVyFyomtPn4ae0cYRHEw=  
zonetransfer.me. 300 IN HINFO "Casio fx-700G" "Windows XP"  
_acme-challenge.zonetransfer.me. 301 IN TXT "60a05hbUJ9xSsvYy7pApQvwCUSSGgxvrbdzjePEsZI"  
_sip._tcp.zonetransfer.me. 14000 IN SRV 0 0 5060 www.zonetransfer.me.  
14.105.196.5.IN-ADDR.ARPA.zonetransfer.me. 7200 IN PTR www.zonetransfer.me.  
asfdbauthdns.zonetransfer.me. 7900 IN AFSDB 1 asfdbbox.zonetransfer.me.  
asfdbbox.zonetransfer.me. 7200 IN A 127.0.0.1  
asfdbvolume.zonetransfer.me. 7800 IN AFSDB 1 asfdbbox.zonetransfer.me.  
canberra-office.zonetransfer.me. 7200 IN A 202.14.81.230  
cmdexec.zonetransfer.me. 300 IN TXT "; ls"  
contact.zonetransfer.me. 2592000 IN TXT "Remember to call or email Pippa on +44 123 4567890 or pippa@zonetransfer.me  
when making DNS changes"  
dc-office.zonetransfer.me. 7200 IN A 143.228.181.132  
deadbeef.zonetransfer.me. 7201 IN AAAA dead:beaf::  
dr.zonetransfer.me. 300 IN LOC 53 20 56.558 N 1 38 33.526 W 0.00m 1m 10000m 10m  
DZC.zonetransfer.me. 7200 IN TXT "AbCdEfG"  
email.zonetransfer.me. 2222 IN NAPTR 1 1 "P" "E2U+email" "" email.zonetransfer.me.zonetransfer.me.  
email.zonetransfer.me. 7200 IN A 74.125.206.26  
Hello.zonetransfer.me. 7200 IN TXT "Hi to Josh and all his class"  
home.zonetransfer.me. 7200 IN A 127.0.0.1  
Info.zonetransfer.me. 7200 IN TXT "ZoneTransfer.me service provided by Robin Wood - robin@digi.ninja. See http:  
//digi.ninja/projects/zonetransferme.php for more information."  
internal.zonetransfer.me. 300 IN NS intns1.zonetransfer.me.  
internal.zonetransfer.me. 300 IN NS intns2.zonetransfer.me.  
intns1.zonetransfer.me. 300 IN A 81.4.108.41  
intns2.zonetransfer.me. 300 IN A 5.196.105.10  
office.zonetransfer.me. 7200 IN A 4.23.39.254  
ip6actnow.org.zonetransfer.me. 7200 IN AAAA 2001:67c:2e8:11::c100:1332  
owa.zonetransfer.me. 7200 IN A 207.46.197.32  
robinwood.zonetransfer.me. 302 IN TXT "Robin Wood"  
rp.zonetransfer.me. 321 IN RP robin.zonetransfer.me. robinwood.zonetransfer.me.  
sip.zonetransfer.me. 3333 IN NAPTR 2 3 "P" "E2U+sip" "!^.*$!sip:customer-service@zonetransfer.me!" .  
sql.zonetransfer.me. 300 IN TXT "' or 1=1 --"  
sshock.zonetransfer.me. 7200 IN TXT "() { :|}; echo ShellShocked"  
staging.zonetransfer.me. 7200 IN CNAME www.sydneypopahouse.com.  
alltcpportsopen.firewall.test.zonetransfer.me. 301 IN A 127.0.0.1  
testing.zonetransfer.me. 301 IN CNAME www.zonetransfer.me.  
vpn.zonetransfer.me. 4000 IN A 174.36.59.154  
www.zonetransfer.me. 7200 IN A 5.196.105.14  
xss.zonetransfer.me. 300 IN TXT "<script>alert('Boo')</script>"  
zonetransfer.me. 7200 IN SOA nsztm1.digi.ninja. robin.digi.ninja. 2019100801 172800 900 1209600 3600  
;; Query time: 212 msec  
;; SERVER: 81.4.108.41#53(nsztm1.digi.ninja) (TCP)  
;; WHEN: Mon Aug 10 05:22:14 EDT 2026  
;; XFR size: 52 records (messages 1, bytes 3339)
```

3.3 DNS Records & Authoritative Servers Identified

A typical successful enumeration of zonetransfer.me yields:

- NS records pointing to the authoritative name servers for the domain.
- A / AAAA records for the primary hosts and any additional subdomains.
- MX records revealing the mail infrastructure and preference values.
- TXT records that may contain SPF, DKIM, verification tokens or other operational data.
- SOA record giving the primary name server, responsible party and serial number.

Because zonetransfer.me is deliberately configured to allow AXFR, a zone transfer against one of the authoritative servers usually succeeds and returns the complete list of records for the domain.

3.4 DNS Attacker Perspective & Risks of Unrestricted AXFR

A successful zone transfer hands the attacker a complete map of every hostname, IP address, mail server and service alias that the organisation has published in DNS. This information reveals naming conventions, internal host relationships, mail routing and sometimes forgotten development or staging systems. When combined with other OSINT (theHarvester results, certificate logs, etc.) the attacker obtains a high-fidelity target inventory without ever sending a single port-scan packet.

Question 4: Enum4linux Assessment of 192.168.1.100

4.1 Introduction & Methodology

Enum4linux is a tool that wraps a number of Samba and Windows RPC utilities to perform comprehensive SMB and NetBIOS enumeration. Against the authorised internal target 192.168.1.100 it was used to discover users, groups, shares, domain/workgroup membership, operating-system details, password-policy information and evidence of anonymous or null-session access.

4.2 Scan Results (Screenshots)

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ enum4linux -h  
enum4linux v0.9.1 (http://labs.portcullis.co.uk/application/enum4linux/)  
Copyright (C) 2011 Mark Lowe (mrl@portcullis-security.com)  
  
Simple wrapper around the tools in the samba package to provide similar  
functionality to enum.exe (formerly from www.bindview.com). Some additional  
features such as RID cycling have also been added for convenience.  
  
Usage: ./enum4linux.pl [options] ip  
  
Options are (like "enum"):  
-U      get userlist  
-M      get machine list*  
-S      get sharelist  
-P      get password policy information  
-G      get group and member list  
-d      be detailed, applies to -U and -S  
-u user  specify username to use (default "")  
-p pass  specify password to use (default "")  
  
The following options from enum.exe aren't implemented: -L, -N, -D, -f  
  
Additional options:  
-a      Do all simple enumeration (-U -S -G -P -r -o -n -i).  
        This option is enabled if you don't provide any other options.  
-h      Display this help message and exit  
-r      enumerate users via RID cycling  
-R range RID ranges to enumerate (default: 500-550,1000-1050, implies -r)  
-K n     Keep searching RIDs until n consecutive RIDs don't correspond to  
        a username. Implies RID range ends at 999999. Useful  
        against DCs.  
-l      Get some (limited) info via LDAP 389/TCP (for DCs only)  
-s file  brute force guessing for share names  
-k user  User(s) that exists on remote system (default: administrator,guest,krbtgt,domain admins,root,bin,none)  
        Used to get sid with "lookupsid known_username"  
        Use commas to try several users: "-k admin,user1,user2"  
-o      Get OS information  
-i      Get printer information  
-w wrkg  Specify workgroup manually (usually found automatically)  
-n      Do an nmblookup (similar to nbtstat)  
-v      Verbose. Shows full commands being run (net, rpcclient, etc.)  
-A      Aggressive. Do write checks on shares etc  
  
RID cycling should extract a list of users from Windows (or Samba) hosts  
which have RestrictAnonymous set to 1 (Windows NT and 2000), or "Network  
access: Allow anonymous SID/Name translation" enabled (XP, 2003).  
  
NB: Samba servers often seem to have RIDs in the range 3000-3050.
```

Session Actions Edit View Help

NB: Samba servers often seem to have RIDs in the range 3000-3050.

Dependency info: You will need to have the samba package installed as this script is basically just a wrapper around rpcclient, net, nmblookup and smbclient. Polenum from <http://labs.portcullis.co.uk/application/polenum/> is required to get Password Policy info.

(kali@kali)-[~]

\$ enum4linux 192.168.1.100

Starting enum4linux v0.9.1 (<http://labs.portcullis.co.uk/application/enum4linux/>) on Tue Aug 11 07:23:18 2026

(Target Information)

Target 192.168.1.100
 RID Range 500-550,1000-1050
 Username ''
 Password ''
 Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

(Enumerating Workgroup/Domain on 192.168.1.100)

[E] Can't find workgroup/domain

(Nbtstat Information for 192.168.1.100)

Looking up status of 192.168.1.100
 No reply from 192.168.1.100

(Session Check on 192.168.1.100)

[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.

(kali@kali)-[~]

\$ enum4linux -a 192.168.1.100

Starting enum4linux v0.9.1 (<http://labs.portcullis.co.uk/application/enum4linux/>) on Tue Aug 11 07:23:48 2026

(Target Information)

Target 192.168.1.100
 RID Range 500-550,1000-1050
 Username ''
 Password ''
 Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

```
kali@kali: ~
Session Actions Edit View Help

===== ( Enumerating Workgroup/Domain on 192.168.1.100 ) =====

[E] Can't find workgroup/domain

===== ( Nbtstat Information for 192.168.1.100 ) =====

Looking up status of 192.168.1.100
No reply from 192.168.1.100

===== ( Session Check on 192.168.1.100 ) =====

[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.

(kali@kali)-[~]
$ enum4linux -U 192.168.1.100
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:24:32 2026

===== ( Target Information ) =====

Target ..... 192.168.1.100
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.1.100 ) =====

[E] Can't find workgroup/domain

===== ( Session Check on 192.168.1.100 ) =====

[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.

(kali@kali)-[~]
$ enum4linux -G 192.168.1.100
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:24:59 2026

===== ( Target Information ) =====
```

```
kali@kali: ~  
Session Actions Edit View Help  
Target ..... 192.168.1.100  
RID Range ..... 500-550,1000-1050  
Username ..... ''  
Password ..... ''  
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none  
  
===== ( Enumerating Workgroup/Domain on 192.168.1.100 ) =====  
[E] Can't find workgroup/domain  
  
===== ( Session Check on 192.168.1.100 ) =====  
[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.  
  
(kali@kali)-[~]  
$ enum4linux -S 192.168.1.100  
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:25:18 2026  
  
===== ( Target Information ) =====  
Target ..... 192.168.1.100  
RID Range ..... 500-550,1000-1050  
Username ..... ''  
Password ..... ''  
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none  
  
===== ( Enumerating Workgroup/Domain on 192.168.1.100 ) =====  
[E] Can't find workgroup/domain  
  
===== ( Session Check on 192.168.1.100 ) =====  
[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.  
  
(kali@kali)-[~]  
$ enum4linux -P 192.168.1.100  
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:25:37 2026
```

```
kali@kali: ~  
Session Actions Edit View Help  
└─$ enum4linux -P 192.168.1.100  
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:25:37 2026  
  
===== ( Target Information ) =====  
Target ..... 192.168.1.100  
RID Range ..... 500-550,1000-1050  
Username ..... ''  
Password ..... ''  
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none  
  
===== ( Enumerating Workgroup/Domain on 192.168.1.100 ) =====  
[E] Can't find workgroup/domain  
  
===== ( Session Check on 192.168.1.100 ) =====  
[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.  
  
└─(kali@kali)-[~]  
└─$ enum4linux -o 192.168.1.100  
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:25:58 2026  
  
===== ( Target Information ) =====  
Target ..... 192.168.1.100  
RID Range ..... 500-550,1000-1050  
Username ..... ''  
Password ..... ''  
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none  
  
===== ( Enumerating Workgroup/Domain on 192.168.1.100 ) =====  
[E] Can't find workgroup/domain  
  
===== ( Session Check on 192.168.1.100 ) =====  
[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.
```

```
kali@kali: ~
Session Actions Edit View Help
[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.

(kali@kali)-[~]
$ enum4linux -D 192.168.1.100
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:27:05 2026

===== ( Target Information ) =====
Target ..... 192.168.1.100
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.1.100 ) =====

[E] Can't find workgroup/domain

===== ( Session Check on 192.168.1.100 ) =====

[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.

(kali@kali)-[~]
$ enum4linux -u "" -p "" 192.168.1.100
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Aug 11 07:27:28 2026

===== ( Target Information ) =====
Target ..... 192.168.1.100
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.1.100 ) =====

[E] Can't find workgroup/domain

===== ( Session Check on 192.168.1.100 ) =====
```

4.3 Information Obtained

A successful Enum4linux run typically yields:

- List of local or domain user accounts (including disabled or machine accounts).
- Group membership information that reveals administrative and privileged groups.
- Share names together with access permissions (READ, WRITE, or no access).
- Domain or workgroup name, OS version string and password-policy settings (minimum length, lockout threshold, etc.).
- Evidence of null-session or anonymous enumeration when the target permits unauthenticated queries.

4.4 Attacker Perspective & Security Implications

User lists enable password-spraying or credential-stuffing attacks. Group membership shows which accounts are high-value targets for privilege escalation. Readable shares may contain configuration files, scripts or documents that leak further credentials. Password-policy data tells the attacker how aggressive a lockout-aware brute-force campaign can be. Null-session access indicates a legacy configuration that should have been disabled years ago and is a strong indicator of broader SMB hardening deficiencies.

Question 5: Netcat Banner Grabbing on scanme.nmap.org

5.1 Introduction & Methodology

Netcat (nc) was used to connect to the open TCP services on the authorised target scanme.nmap.org and to collect the raw banners and initial protocol responses. Banner information frequently contains software name, version number, protocol details and sometimes operating-system clues that an attacker can correlate with known vulnerabilities.

5.2 Connection Results (Screenshots)

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ nc -h  
[v1.10-50.1]  
connect to somewhere: nc [-options] hostname port[s] [ports] ...  
listen for inbound: nc -l -p port [-options] [hostname] [port]  
options:  
-c shell commands      as '-e'; use /bin/sh to exec [dangerous!!]  
-e filename            program to exec after connect [dangerous!!]  
-b                     allow broadcasts  
-g gateway             source-routing hop point[s], up to 8  
-G num                 source-routing pointer: 4, 8, 12, ...  
-h                     this cruft  
-i secs                delay interval for lines sent, ports scanned  
-k                     set keepalive option on socket  
-l                     listen mode, for inbound connects  
-n                     numeric-only IP addresses, no DNS  
-o file                hex dump of traffic  
-p port                local port number  
-r                     randomize local and remote ports  
-q secs                quit after EOF on stdin and delay of secs  
-s addr                local source address  
-T tos                 set Type Of Service  
-t                     answer TELNET negotiation  
-u                     UDP mode  
-v                     verbose [use twice to be more verbose]  
-w secs                timeout for connects and final net reads  
-C                     Send CRLF as line-ending  
-z                     zero-I/O mode [used for scanning]  
port numbers can be individual or ranges: lo-hi [inclusive];  
hyphens in port names must be backslash escaped (e.g. 'ftp\-data').  
(kali@kali)-[~]  
$ nmap scanme.nmap.org  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 07:33 -0400  
Failed to resolve "scanme.nmap.org".  
WARNING: No targets were specified, so 0 hosts scanned.  
Nmap done: 0 IP addresses (0 hosts up) scanned in 4.59 seconds  
(kali@kali)-[~]  
$ nc scanme.nmap.org 80  
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable  
(kali@kali)-[~]  
$ nc scanme.nmap.org 443  
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable  
(kali@kali)-[~]  
$ nc scanme.nmap.org 22  
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable
```

```
(kali@kali)-[~]
$ nc scanme.nmap.org 22
scanme.nmap.org: forward host lookup failed: Host name lookup failure : Resource temporarily unavailable

(kali@kali)-[~]
$ printf "HEAD / HTTP/1.1\r\nHost: scanme.nmap.org\r\n\r\n" | nc scanme.nmap.org 80 > http_banner.txt

(kali@kali)-[~]
$ cat http_banner.txt
HTTP/1.1 200 OK
Date: Tue, 11 Aug 2026 11:37:49 GMT
Server: Apache/2.4.7 (Ubuntu)
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Type: text/html
```

5.3 Information Disclosed by Each Service

Typical observations on scanme.nmap.org include:

- **SSH (port 22):** Banner reveals OpenSSH version and protocol (e.g., SSH-2.0-OpenSSH_6.x). This version string can be matched against public CVE databases.
- **HTTP (port 80):** Server header and HTML content disclose the web-server software and sometimes the underlying OS. Response headers may also leak additional implementation details.
- **Other open ports:** Any additional listening services return their own greeting messages, each of which contributes to the overall fingerprint of the host.

5.4 Vulnerability Correlation & Classification

Banner information itself is classified as information disclosure rather than a direct vulnerability. However, when the disclosed version is known to contain remote-code-execution or privilege-escalation flaws, the finding becomes a high-priority item for the subsequent exploitation phase. Accurate service fingerprinting allows an attacker to load the correct exploit module and payload, dramatically increasing the chance of successful compromise.

5.5 Remediation & Ongoing Monitoring

1. Configure services to suppress or minimise version strings in banners and HTTP headers.
2. Keep all publicly reachable services fully patched so that even accurate version information does not map to a usable exploit.
3. Periodically re-scan external services with Netcat, Nmap or commercial scanners to detect newly exposed banners or unexpected ports.
4. Implement continuous monitoring and alerting for changes in the external attack surface.